

Trust by Construction for Secure Agentic Workflows in Learning Institutions

An executable reference architecture for bounded authority and failure recovery

Rachana (Gen) Srivastava

UNU Macau AI Conference 2026

Abstract

Agentic AI can retrieve student records, retain memory, delegate work and change institutional systems. Reliable answers alone do not establish legitimate authority for these actions. We present Trust by Construction, an executable reference architecture that treats both acting and reviewing models as untrusted components. Independently enforced task contracts constrain protected reads, state changes and disclosure; authority attenuates across delegation and is revalidated when an effect commits or an approved artifact is delivered. The central property is authority non-expansion: model outputs may select among permitted operations or trigger restrictions, but cannot authorise an operation outside the current institutional envelope. The contribution is a composition of capability control, data lineage, independent approval, durable revocation and failure-aware delivery, together with tests that make violations observable. A separate release-channel experiment illustrates why approved content can still disclose information through metadata and release count. An Apache-2.0 reference implementation supplies reproducible mechanism tests and explicit deployment qualification requirements. Evidence comes from controlled synthetic fixtures, not institutional deployment. The architecture offers learning institutions an inspectable engineering basis for agent integration and a practical way to teach the distinction between model capability, legitimate authority and substantive correctness.

Keywords: agentic AI; capability security; information-flow control; education governance; reproducible systems research

1 Problem and contribution

A transcript assistant should retrieve the record needed for a correction, propose a change, and release the approved result to its intended recipient. It should not gain access to another student's record because a retrieved document asks it to, approve its own proposal, or continue using a lease revoked during delivery. This example exposes the engineering question addressed here: how can useful model reasoning remain available while institutional power is independently bounded?

Trust by Construction separates proposals from authority. Its contribution is the integration of established security mechanisms across the lifecycle of an agent task, especially at boundaries that survive a model call: memory, delegation, revocation, delivery and uncertain remote effects. It contributes three things: a falsifiable authority invariant; an executable enforcement path with named failure tests; and an analysis of residual information disclosure through otherwise permitted release choices. It does not introduce a new alignment algorithm or claim a formal verification of arbitrary agent programs.

System-level mitigations complement model-level safety work [1]. CaMeL separates control and data flow to defend against prompt injection [2]. Research on anti-scheming training, monitorability, insider behaviour, reward hacking and sabotage motivates testing enforcement even when an acting or reviewing model is unreliable [3–8]. Proposals for non-agentic Scientist AI address a related but different design question [9]. AgentSecBench and AgentDyn evaluate agent security and the security–utility trade-off under different task conditions [10,11]. Our contribution concerns persistent authority and failure handling, without a benchmark-ranking or head-to-head superiority claim.

Table 1. Position relative to prior work. These are differences in scope, not comparative performance results.

Prior work	Established focus	Contribution examined here
Capabilities and information flow [13–19]	Access boundaries, attenuation, lineage and independent roles	Composition across an agent task and its failure paths
CaMeL [2]	Control/data separation against prompt injection	Persistent memory, revocation and delivery contracts
AgentSecBench and AgentDyn [10,11]	Agent security evaluation under defined tasks	Named invariant checks, without benchmark ranking
Monitoring [3–8]	Model behaviour and the limits of detection	Monitoring that cannot grant or restore authority
Confinement [20,21]	Information carried through permitted behaviour	Encoder-specific release traces and policy costs

The design draws on complete mediation and least privilege [13], capabilities and attenuation [14,15], lattice-ordered information flow [16], noninterference [17], integrity models [18] and separation of duty [19]. These foundations are credited as prior work. The novel engineering question is whether their composition preserves the declared boundary when an agent delegates, a monitor fails, a task is revoked or an external call becomes uncertain.

Table 2. Core terminology. The implementation uses these concepts across domain profiles.

Term	Meaning	Boundary
Passport	Approved workload ceiling	Admission
Task contract	Scope and purpose of one execution	Each mediated request
Capability envelope	Operations currently permitted by intersected rights	Authorisation
Attenuation	Delegation only of a subset of existing rights	Agent or service delegation
Lineage	Source restrictions retained through derivation	Retrieval, memory and release
Release escrow	Approval bound to exact bytes and a recipient	Disclosure
Refusal	No protected operation when its checks fail	Every protected interface

2 Threat model and authority invariant

The adversary may control model outputs, injected source content, tool descriptions and results, prior memory, delegated messages and the verdict of an AI monitor. It may adapt its requests, replay them and select among permitted operations. We assume authenticated operator actions, an integrity-protected control store, correct enforcement code and keys outside the model's control. Deployment must prevent bypass through host files, sockets, credentials or undeclared interfaces. Compromise of these trusted components is outside the evaluated guarantee; the reference Python process itself does not provide that isolation.

Let s denote the trusted state at a mediation boundary, including identity, policy, task contract, approvals, lineage, resource versions, revocation epochs and remaining budget. Let $A(s)$ be the set of protected operations independently permitted by that state. Let $O(s,m,r)$ denote the protected operations admitted for model proposals m and reviewer findings r . The required invariant holds for every m and r .

Property 1 Authority non-expansion

$$O(s,m,r) \subseteq A(s) \quad (1)$$

An automated restriction may reduce the effective envelope but cannot add authority. This is an invariant over each admitted transition, with s refreshed at the boundary. It does not say that all models produce identical outcomes: models may choose different permitted requests, and a hostile monitor may deny all useful work. A counterexample is one admitted operation outside $A(s)$, or an automated transition that expands the permitted envelope. A refusal or a change between two authorised actions is not a counterexample.

Equation (1) is a specification, not a theorem proved for the complete implementation. The design argument is conditional: if every protected interface authenticates its caller, recomputes current authority, validates the operation and commits under the required concurrency checks, then model text supplies candidate requests rather than new rights. Its validity depends on those checks being complete and correct. The mechanism tests in Section 5 challenge these conditions through substitution, replay, revocation and control ablation.



Figure 1. Enforcement path. The separation shown is an architectural requirement; host isolation and adapter correctness require deployment qualification.

The monitor follows a restricted integrity policy inspired by [18]: lower-trust advice can trigger a separately specified restriction, but cannot confer approval. This intentionally permits denial of service. Restoring authority requires an authenticated operator and remains bounded by the workload's independently established ceiling. Authorisation correctness also differs from semantic correctness: an authorised transcript correction may still be factually wrong.

3 Enforcement across the task lifecycle

The enforcement contract has five steps: authenticate the caller; load current trusted state; intersect the applicable rights; validate the exact operation and its dependencies; then commit under the interface's concurrency and replay checks. A failed check yields no protected operation. State used for a decision must still be valid at commitment: a cached approval cannot override a newer revocation or resource version. This is a normative interface contract, not a claim that a remote effect and a local ledger share one atomic transaction; Section 4.1 gives the separate remote-effect rule.

3.1 Admission and delegation

An AI Workload Passport declares the workload ceiling: data classes, models, tools, processing zones, network destinations, delegation depth, budgets, effects and safe failure state. An Effect and Disclosure Inventory identifies the interfaces that can change state or release information. A Task Contract narrows that

ceiling to one purpose, subject, resource set, destination and expiry. The effective envelope intersects these declarations with current identity, lineage, ancestor scopes, policy and remaining budget.

Agents hold short-lived scoped leases rather than standing database or cloud credentials. Delegated agents receive subsets of their ancestors' authority; population, depth and shared task budgets prevent spawning from multiplying rights. A declared-graph check rejects protected-source-to-public-sink paths across cooperating agents. This check covers registered topology, not discovery of hidden operating-system channels. Byte-based compute accounting in local adapters is not a measurement of GPU use or provider billing.

3.2 Retrieval and memory

A context gateway authorises protected retrieval before records reach the model and limits cumulative scope. A memory gateway treats persistence as a privileged write and reauthorises later reads. Derived data retains source restrictions across summaries, handoffs, proposals and artifacts. In lattice terms, derivation must not weaken the restrictions of its inputs [16]. Transformation does not itself authorise declassification.

An operator can quarantine an exact source binding. Tracked derivative memory, proposals and releases then become unavailable, including after service restart or retrieval by a fresh agent. Repair requires a new source binding. The guarantee depends on complete lineage capture; it does not erase information already observed or recall bytes already delivered.

3.3 Effects and approval

The model proposes a typed intermediate representation containing canonical resource identifiers and a desired state transition. It supplies no credentials, arbitrary SQL, shell command or policy declaration. The executor revalidates the caller, lease, current resource version, replay state, destination and domain invariants before committing. Source confirmation and independent approval bind the exact proposal rather than an open-ended instruction.

In the transcript example, the agent retrieves only the authorised record and proposes a version-bound correction. A source role confirms supporting evidence and a different reviewer approves the proposal. If the record changes, the task expires or its authority is revoked before execution, the proposal must be rejected or reviewed again. Capability checks establish who may act; the reviewer remains responsible for whether the proposed correction is justified [19].

3.4 Disclosure and stopping

Release escrow binds approval to exact artifact bytes and an authorised recipient. Exact-byte binding prevents post-approval substitution; it does not establish that a human-approved artifact is truthful or free of sensitive information. Delivery rechecks recipient identity, task epoch, destination, expiry, stop state and source quarantine at each chunk boundary. Revocation denies subsequent chunks; it cannot recall bytes already committed. This is staged artifact delivery, not live model-token streaming.

A concrete refusal trace makes the boundary observable. The delivery test approves the artifact “abcdefghij” and delivers “abc”. It then independently exercises five changes: revocation, contract restriction, expiry, emergency stop and source invalidation. In each case, both the next chunk and a bulk-delivery attempt are denied, and the delivery cursor remains at three bytes. Previously delivered bytes remain with the recipient. This tests both reauthorisation and the absence of a bulk fallback around the chunk boundary.

Emergency stopping durably revokes agents, quarantines tasks and advances epochs before attempting to record evidence. An evidence-writer failure cannot reverse the stop. Resumption requires a named operator, a new task and fresh authority. The stop controls declared service authority, not operating-system processes. Authenticated blocked attempts remain observable without allowing unknown tokens to grow the evidence chain.

3.5 Monitoring without approval power

A separately deployed monitor receives allowlisted metadata rather than protected text and returns a constrained finding. It may request a restrictive state transition; a clear verdict never restores privilege. Findings bind to fresh task and global evidence heads and are rejected if forged, stale, replayed or submitted under another role. Restrictive states include RESTRICTED, PROPOSAL_ONLY, READ_ONLY and QUARANTINED.

This mechanism makes detector failure an availability or missed-detection problem rather than a new grant of authority. It cannot identify malicious intent in every authorised request. A model whose harmful objective is achievable entirely within an overly broad contract remains a policy-design problem.

4 Failure handling and deployment contracts

4.1 External effects and evidence

A local transaction cannot atomically commit an arbitrary remote effect [22]. The reference ledger records intent before submission and uses an operation-bound key. An unacknowledged call remains uncertain and blocks dependent work; it is not blindly resubmitted. Reconciliation requires an applied acknowledgement or authoritative terminal absence. Pending responses and eventually consistent absence cannot establish settlement.

The local control provides at-most-once submission within its ledger contract. End-to-end effect semantics depend on the provider: lookup can establish status, while deduplication or equivalent transactional guarantees are needed to prevent duplicate application. Lookup alone does not establish exactly-once execution. A provider without authoritative lookup may leave the effect permanently uncertain.

Cross-service grants are signed, audience-bound, single-use and depth-limited. A receiving service intersects the grant with its own ceiling. Evidence chaining detects changes relative to a trusted head [23]; independent threshold witnesses strengthen custody and expose conflicting heads. Neither signatures nor chained records prove the factual truth of the underlying event.

4.2 Host and transport qualification

The model must be unable to write the control database, alter enforcement code or reach protected services outside mediation. Isolation probes inspect these assumptions and classify required measurements as satisfied, violated or not measurable. A missing measurement is not a pass. Cooperative probes support diagnosis but do not replace adversarial testing of the intended host boundary.

Transport contracts require pinned addresses, TLS peer verification, redirect reauthorisation and byte ceilings. The implemented fetch path additionally verifies an independently approved artifact digest: an authenticated peer does not make changed content acceptable. Tests exercise concurrent transfers, content substitution and malformed framing using a loopback TLS peer. Such evidence qualifies the tested code path; the promotion gate rejects it as proof of institutional network qualification.

4.3 Tool supply and extension boundaries

Server-qualified tool names avoid ambiguous resolution. Approval binds the description and interface bytes the model will read; drift or server-identity changes invalidate approval. Scanning descriptions can inform human review but cannot prove them benign. Privileged tool use is also restricted by the provenance of the call chain. These controls address prompt injection, supply-chain changes and excessive agency described in OWASP's risk taxonomy [27].

Deployment adapters remain trusted components. They must enforce identity, transaction boundaries, destination semantics and provider settlement contracts. Host confinement, credential custody, physical

erasure and the model-training lifecycle are separate responsibilities. Passing a conformance suite is evidence for specified behaviour, not permission to bypass these obligations.

5 Verification method and bounded evidence

The evaluation uses scripted adversarial and benign fixtures over declared interfaces. It contains no student records, human participants or institutional production traffic. The objective is to test enforcement mechanisms under specified failures, not estimate field attack rates or educational benefit. Reference experiments, named tests and generated reports are supplied in the artifact.

The controlled comparison uses the same seven hostile and two benign proposals per arm: unguarded execution, a safety prompt with a tool allowlist, and the mediated architecture. No live-model compliance with the safety prompt is measured. Containment is the fraction of those hostile proposals whose prohibited effect is prevented. Cross-sector scenarios exercise six configured profiles; they are not six institutional deployments. Ablation removes one tested control at a time and checks whether its associated harmful operation becomes possible. Bounded falsification searches the declared state space, with no claim about unenumerated states.

Table 3. Recorded mechanism evidence. Counts across rows overlap and must not be added; test cases and search attempts are not independent field attacks.

Check	Recorded result	Interpretation
Controlled comparison	0/7 → 2/7 → 7/7 hostile proposals contained	Unguarded → prompt/allowlist → mediated; not field rates
Six domain profiles	180/180 hostile contained; 58/58 benign completed	Configured profiles, not institutional deployments
Control ablation	Each of 8 removals enables an associated harmful action	Control relevance within those scenarios
Bounded falsification	104,997 attempts; no counterexample found	Only the declared bounded search space
Recorded regression	1,445 tests passed; 37 capability contracts executed	Source-bound local evidence, not production certification
Monitor substitution	No tested prohibited outcome; hostile-monitor benign utility is zero	Authority safety and availability are different properties
Deployment qualification	Controlled host and TLS checks; no production qualification	Institution-specific host and transport evidence remains required

The adversarial monitor substitution is the most direct check of Property 1. An oracle, a blind monitor and a hostile monitor are run against the same held-out scripted trajectories. None permits the prohibited outcome tested by the harness. The hostile monitor nevertheless reduces retained benign utility to zero. This supports authority non-expansion while demonstrating that containment does not imply service availability or good detector performance.

The evidence also exposes institutional limits. A human reviewer can become a throughput bottleneck, and a reviewing assistant that shares the proposing model and evidence may repeat its substantive mistakes. Independent roles, adequate review capacity and evidence quality cannot be inferred from a valid capability chain. The artifact includes an institutional study plan, but that study has not been run.

6 Information carried by permitted release choices

Content approval leaves another channel: an agent may choose the destination, path, time, size or count of otherwise permitted releases. Eight distinguishable destinations can encode three bits per choice. The

confinement problem [20] and information theory [21] explain this risk; Silent Egress provides recent motivation for observing outbound actions rather than only final answers [12].

Let Z be the enumerated secret set, f the tested encoder, P a release policy and $T(P, f, z)$ the observer's trace. The experiment reports the trace-alphabet measure

$$L(P, f) = \log_2 |\{T(P, f, z) : z \in Z\}| \quad (2)$$

For this fixed deterministic mapping, mutual information is bounded above by $L(P, f)$; equality depends on the induced distribution over traces. The statistic is neither an estimate of average leaked bits nor an upper bound over every possible encoder. The observer sees destination, path, slot, size and release count, but not payload content, network jitter or operational side channels. This restricted observation model is essential to interpreting zero.

Across all 65,536 sixteen-bit secrets, the supplied encoder produces 65,536 distinct traces without controls, two under the intermediate policy and one under the sealed policy: L is respectively 16, 1 and 0 bits. The intermediate policy fixes destination and path, coarsens timing and pads sizes to buckets. Its declared policy bound remains wider than the two traces reached by this encoder; untested encoders may exploit the remaining choices.

The sealed policy additionally fixes the release count at two and reduces timing and size alternatives to one slot and one bucket, adding cover emissions in the observation model. Consequently, the last reduction cannot be attributed to release-count control alone. One trace establishes observational equivalence only for the enumerated secrets, encoder and observation model [17]. Actual payloads and cover traffic would need separate validation to establish indistinguishability on a real network.

Both constrained policies escalate 64,512 of 65,536 adversarial tasks, approximately 98.4%. The single benign workflow completes its two releases under every policy. This is a narrow feasibility check, not evidence that ordinary workloads generally retain utility. Padding, cover traffic, scheduling delay and review demand impose costs; production bandwidth, latency and reviewer workload are not measured here. The engineering lesson is to remove unnecessary choice and expose the cost of the remaining policy, rather than equate a clean payload with no disclosure.

7 How to extend the reference

The public SDK exposes context, capability, tool, memory, proposal and release operations, plus separate operator and recipient interfaces. The shortest integration path is one bounded workflow. A new institution should first identify its authoritative records, permitted purpose, reviewer roles, delivery destination and failure response. Domain packs parameterise these choices; they do not replace institutional policy analysis.

An extension should produce four reviewable artifacts. First, a domain profile declares subjects, resources, purposes, tools, effects and budgets. Second, a capability contract identifies the protected asset, permitted operation, enforcement point, accountable owner, failure test, evidence artifact and failure response. Third, an adapter maps the institution's service onto the contract, including versions, retries, uncertainty and identity. Fourth, a claim entry links the written guarantee to named tests and generated evidence.

For example, adding a scholarship decision workflow requires a decision resource and permitted transition, independently defined approval roles, and tests for cross-student access, stale approval, replay and revocation before delivery. This is a proposed extension recipe, not an evaluated scholarship deployment. A new declaration can reuse existing primitives; a genuinely new enforcement mechanism may require core changes and a renewed review of the invariant. Extensibility is not a claim that every future control can be added without changing code.

Run benign completion and refusal tests together, then the cross-boundary cases: delegation followed by revocation, source quarantine after approval, and lost acknowledgement after external submission. These

combinations test composition rather than the presence of isolated checks. Add the deployment evidence only after testing against the institution's actual host, transport and service semantics.

8 Education relevance and limits

For AI for Learning, the architecture makes access and intervention in student workflows inspectable. For Learning for AI, the transcript example supports a practical exercise: learners compare a valid correction with forged approval, contaminated memory and a misleading monitor. The learning objective is to distinguish fluent reasoning, source validity, legitimate authority and correct decisions. No measured learning improvement is claimed.

The proposed governance mapping is specific. Task contracts record scope and responsibility; test and refusal evidence supports risk measurement; revocation and recovery support operational response. These artifacts can contribute to the GOVERN, MAP, MEASURE and MANAGE functions of NIST AI RMF [24]. The EU AI Act identifies specified educational uses in Annex III and addresses matters including records and human oversight [25]. Applicability depends on the use case and legal scope; neither passing tests nor adopting this architecture establishes conformity.

UNESCO's guidance foregrounds human agency, inclusion and institutional capacity [26]. SDG 4 provides the wider motivation of inclusive, equitable education [28]. Offline execution and openly licensed interfaces may lower the cost of inspecting and adapting a reference implementation, but reduced cost and equitable access have not been measured. The artifact is offered as an open resource; this does not claim formal recognition under a digital-public-goods certification scheme.

The central limitations are substantive. The implementation trusts service state and its enforcement components. No live frontier-model detector, adversarial host-isolation study or production deployment is evaluated here. No general noninterference proof, comparative performance study, fairness result or student-outcome study is supplied. Strict controls may deny useful work; correct authorisation may still permit an incorrect institutional decision. The next empirical step is a separately governed institutional pilot measuring completion, refusal reasons, reviewer burden and subgroup outcomes under a fixed analysis plan.

9 Conclusion

Trust by Construction makes institutional authority an independently checked condition of agent action. Its technical contribution is the composition of bounded delegation, lineage, approval, revocation and delivery under explicit failure semantics. The reference provides executable counterexample searches and refusal tests, while distinguishing those results from deployment assurance. Learning institutions can use this separation both to engineer agent integrations and to teach why stronger model capability must not silently expand the power to read, change or disclose institutional records.

Artifact availability and reproduction

The Apache-2.0 reference is available at <https://github.com/genaiworks/fssai-ra>; begin with DEVELOPER_GUIDE.md. Install the declared development dependencies, then run `python -m pytest, python scripts/check_tbc_alignment.py, python scripts/check_architecture.py` and `python scripts/generate_results.py --check`. The complete repository check is `make all`; `make covert-channels` regenerates the release-choice report. No model weights, GPU or real student data are needed; TLS tests require loopback sockets.

Run `python -m pytest tests/test_frontier_controls.py` for the principal failure checks. Within that file, the `pytest -k` selectors “stream_reauthorizes”, “stop_stays_effective” and “ai_monitor_can_contract” respectively exercise the five delivery changes in Section 3.4, evidence-writer failure during stopping, and rejection of monitor-driven restoration. The source-bound claim register supplies the wider claim-to-test mapping. Table 3 reports recorded full-suite evidence; these local checks do not qualify an institutional deployment.

References

- [1] R. Shah et al. (2025). An Approach to Technical AGI Safety and Security. arXiv preprint 2504.01849. <https://arxiv.org/abs/2504.01849>
- [2] E. DeBenedetti et al. (2025). Defeating Prompt Injections by Design. arXiv preprint 2503.18813. <https://arxiv.org/abs/2503.18813>
- [3] B. Schoen et al. (2025). Stress Testing Deliberative Alignment for Anti-Scheming Training. arXiv preprint 2509.15541. <https://arxiv.org/abs/2509.15541>
- [4] T. Korbak et al. (2025). Chain of Thought Monitorability: A New and Fragile Opportunity for AI Safety. arXiv preprint 2507.11473. <https://arxiv.org/abs/2507.11473>
- [5] A. Lynch et al. (2025). Agentic Misalignment: How LLMs Could Be Insider Threats. arXiv preprint 2510.05179. <https://arxiv.org/abs/2510.05179>
- [6] M. MacDiarmid et al. (2025). Natural Emergent Misalignment from Reward Hacking in Production RL. arXiv preprint 2511.18397. <https://arxiv.org/abs/2511.18397>
- [7] J. Kutasov et al. (2025). SHADE-Arena: Evaluating Sabotage and Monitoring in LLM Agents. arXiv preprint 2506.15740. <https://arxiv.org/abs/2506.15740>
- [8] R. Kirk et al. (2026). Evaluating whether AI models would sabotage AI safety research. arXiv preprint 2604.24618. <https://arxiv.org/abs/2604.24618>
- [9] Y. Bengio et al. (2025). Superintelligent Agents Pose Catastrophic Risks: Can Scientist AI Offer a Safer Path? arXiv preprint 2502.15657. <https://arxiv.org/abs/2502.15657>
- [10] F. Alpay and T. Alpay (2026). AgentSecBench: Measuring Prompt Injection, Privacy Leakage, and Tool-Use Integrity in LLM Agents. arXiv preprint 2605.26269. <https://arxiv.org/abs/2605.26269>
- [11] H. Li et al. (2026). AgentDyn: Are Your Agent Security Defenses Deployable in Real-World Dynamic Environments? arXiv preprint 2602.03117. <https://arxiv.org/abs/2602.03117>
- [12] Q. Lan et al. (2026). Silent Egress: When Implicit Prompt Injection Makes LLM Agents Leak Without a Trace. arXiv preprint 2602.22450. <https://arxiv.org/abs/2602.22450>
- [13] J. H. Saltzer and M. D. Schroeder (1975). The Protection of Information in Computer Systems. *Proceedings of the IEEE*, 63(9):1278-1308. <https://www.mit.edu/~Saltzer/publications/protection/Basic.html>
- [14] J. B. Dennis and E. C. Van Horn (1966). Programming Semantics for Multiprogrammed Computations. *Communications of the ACM*, 9(3):143-155.
- [15] M. S. Miller (2006). Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control. PhD thesis, Johns Hopkins University. <https://www.erights.org/talks/thesis/>
- [16] D. E. Denning (1976). A Lattice Model of Secure Information Flow. *Communications of the ACM*, 19(5):236-243.
- [17] J. A. Goguen and J. Meseguer (1982). Security Policies and Security Models. *IEEE Symposium on Security and Privacy*, pp. 11-20.
- [18] K. J. Biba (1977). Integrity Considerations for Secure Computer Systems. MITRE Technical Report ESD-TR-76-372.
- [19] D. D. Clark and D. R. Wilson (1987). A Comparison of Commercial and Military Computer Security Policies. *IEEE Symposium on Security and Privacy*, pp. 184-194.
- [20] B. W. Lampson (1973). A Note on the Confinement Problem. *Communications of the ACM*, 16(10):613-615.
- [21] C. E. Shannon (1948). A Mathematical Theory of Communication. *Bell System Technical Journal*, 27(3):379-423. <https://doi.org/10.1002/j.1538-7305.1948.tb01338.x>
- [22] A. D. Birrell and B. J. Nelson (1984). Implementing Remote Procedure Calls. *ACM Transactions on Computer Systems*, 2(1):39-59.
- [23] S. Haber and W. S. Stornetta (1991). How to Time-Stamp a Digital Document. *Journal of Cryptology*, 3(2):99-111.
- [24] National Institute of Standards and Technology (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. <https://doi.org/10.6028/NIST.AI.100-1>
- [25] European Parliament and Council (2024). Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence. *Official Journal of the European Union*. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>
- [26] UNESCO (2023). Guidance for Generative AI in Education and Research. UNESCO, Paris. <https://unesdoc.unesco.org/ark:/48223/pf0000386693>
- [27] Open Worldwide Application Security Project (2025). OWASP Top 10 for Large Language Model Applications 2025. OWASP Foundation. <https://genai.owasp.org/llm-top-10/>
- [28] United Nations General Assembly (2015). Transforming Our World: The 2030 Agenda for Sustainable Development. Resolution A/RES/70/1. <https://sdgs.un.org/2030agenda>